

Packaging Compliance AI

Security Audit & Posture Report

Generated: July 19, 2026

Owner: Dollar Tree — Packaging Compliance

Classification: Internal

Technology stack: React 19 + Vite web client, Express 5 API, PostgreSQL (Drizzle ORM), Clerk authentication, Replit deployment

Executive Summary

The most recent security audit (2026-07-19) covered authentication and authorization across the entire application and found 0 critical and 0 high-severity vulnerabilities. Passed — zero vulnerabilities requiring fixes.

The platform maintains 18 enforced security controls across authentication, authorization and tenancy, application hardening, AI safety, and audit/operations, with 1 formally accepted risk documented below.

Audit History

2026-07-19 — Passed — zero vulnerabilities requiring fixes.

Scope: Full authentication & authorization audit: IDOR/ownership on every route, backend auth middleware coverage, client-side token storage, tokens in URLs, client-trusted identity values, mutation ownership, ID enumeration, unauthenticated endpoints, and file-serving access control.

Findings: 0 critical, 0 high.

- All flagged candidates were verified against source and confirmed safe by design.
- AI provider settings are intentionally global (company-wide configuration) and admin-permission gated — not a tenancy gap.
- Sequential integer IDs recorded as an accepted risk; org scoping neutralizes enumeration.
- Load-test auth bypass confirmed hard-disabled in production and secret-gated in development.

Security Controls

Authentication

Global backend auth guard **ENFORCED**

Every /api route is protected by server-side session verification (Clerk). The only unauthenticated endpoints are static health checks and the MCP gateway, which enforces its own bearer-token auth with full tenant isolation.

Employees-only access **ENFORCED**

Sign-in is restricted to approved corporate email domains via a server-side 403 gate; non-allowed accounts are rejected and purged on confirmed non-allowed email.

No tokens in URLs or browser storage **ENFORCED**

Sessions live in httpOnly cookies managed by the identity provider SDK. No JWTs or session values are stored in localStorage/sessionStorage or passed in URL query parameters. Upload URLs are short-lived presigned storage URLs, not credentials.

Authorization & Tenancy

Role-based access control **ENFORCED**

Fine-grained permission keys (e.g. packages:read, org:manage) gate every route server-side and every navigation item client-side from a single shared mapping, so UI and API can never drift.

Organization data scoping **ENFORCED**

All identity and tenancy values (user, organization, supplier) derive exclusively from the verified server session — never from request bodies or query strings. Every data query filters by the caller's organization.

Supplier isolation **ENFORCED**

Supplier accounts are restricted to their own supplier's records via mandatory scoping helpers; supplier IDs are forced server-side and cannot be spoofed by the client.

Ownership checks on all mutations **ENFORCED**

Every update and delete verifies the record belongs to the caller's organization (returning 404 otherwise) before writing. File and thumbnail serving verify object ownership before streaming bytes.

Sequential integer IDs (accepted risk) **ACCEPTED RISK**

Resource URLs use auto-increment integer IDs. Enumeration is harmless because every fetch-by-id also enforces organization scoping (guessing a foreign ID returns 404). Accepted for this internal single-company tool; UUID migration deemed churn without security gain.

Application Hardening

API rate limiting **ENFORCED**

Per-user (falling back to per-IP) rate limiting on API routes, with a second layer on the external MCP gateway.

Upload validation & stored-XSS defense **ENFORCED**

Uploads are validated by extension allowlist with size limits. Stored-XSS is neutralized at serve time (content-type / disposition hardening), not just at upload, so hostile files can never execute in the app origin.

Security headers **ENFORCED**

Helmet-managed HTTP security headers on all responses.

SSRF validation on outbound URLs **ENFORCED**

Administrator-configured AI provider base URLs are validated against SSRF (no private/internal address targets) before the server will call them.

AI Safety

Prompt-injection hardening **ENFORCED**

Every LLM call fences untrusted document/user-supplied data with explicit boundaries and an untrusted-data directive, so extracted artwork text cannot steer the model.

Legal guardrails on AI findings **ENFORCED**

Low-confidence or uncertain AI compliance findings are deterministically prevented (in code, not prompts) from being surfaced as definitive violations.

Encrypted AI provider keys **ENFORCED**

Third-party AI API keys are encrypted at rest (AES-256-GCM) and never returned to any client; only the last four characters are shown for identification.

Grounded AI tool tenancy **ENFORCED**

The AI workspace and external MCP gateway share one read-only tool registry as the single security boundary: tools are permission-offered AND query-scoped to the caller's organization/supplier.

Audit & Operations

Append-only audit trail **ENFORCED**

Security-relevant actions (role changes, finding updates, deletions, MCP tool calls) are written to an append-only audit ledger with before/after detail; older events archive rather than delete.

Soft delete with locked purge window **ENFORCED**

Package deletion is a recoverable trash state with a 30-day locked purge; storage objects are reference-counted before removal.

Managed secrets **ENFORCED**

All credentials (database, identity, AI, storage) live in platform-managed environment secrets — never in source control or client bundles.

This report is generated from the platform's live security-posture catalog. The same catalog powers the Security Posture page in the Administration section, which additionally shows real-time system health. Update the catalog when controls change or new audit rounds complete.